

Bug Report — Member 3 (23127185)

Sinh viên: Mai Thị Kim Duyên — MSSV 23127185 — Branch me lyen **SUT:** EShop backend `http://localhost:3000` (seed lại bằng `node database.js` trước mỗi run) **Evidence chính:** `newman/member-3/bug-discovery-report.html` (Bug Discovery Suite — 86 requests, 69 assertion failures, 0 script errors) **Oracle:** `eshop-sut/api_specification.md` + SRS. Assertion trong suite Discovery bám **spec**, không bám hành vi SUT.

Quy ước severity: **Critical** (mất tiền / leo quyền / bypass kiểm soát) · **High** (sai logic nghiệp vụ nghiêm trọng) · **Medium** (validation yếu, lỗi UX/API contract) · **Low**.

BUG-M3-001 — FR-01: Đăng ký không validate gì, luôn trả 200

- **API:** `POST /api/register`
- **Severity:** High
- **Spec:** email phải hợp lệ + duy nhất; password ≥ 8 , có hoa/thường/số/ký tự `@$!%*?&`; thiếu/sai phải trả 400 (`api_specification.md`, FR-01).
- **SUT:** trả 200 cho mọi body: email `"not-an-email"`, password `"1"`, thiếu field, name rỗng.
- **Evidence:** M3-FR01-005...020 trong Discovery Suite (mọi case invalid đều fail vì SUT trả 200 thay vì 400).
- **Root cause:** handler register trong `server.js` không có nhánh validation nào trước INSERT.
- **Issue:** (điền link sau khi tạo)

BUG-M3-002 — FR-01: Email trùng vẫn đăng ký được (kể cả khác case)

- **Severity:** Medium
- **Spec:** email duy nhất → 409.
- **SUT:** đăng ký lại `coupon_user@eshop.com` trả 200 (hoặc 500 nếu UNIQUE constraint của SQLite kịp chặn — thông báo lỗi thô, không phải 409 JSON theo spec). Đăng ký `Admin@eshop.com` khi đã có `admin@eshop.com` cũng 200.
- **Evidence:** M3-FR01-021 (duplicate exact), M3-FR01-H01 (case-insensitive duplicate).
- **Issue:** (điền link)

BUG-M3-003 — FR-01: Content-Type không phải JSON gây crash 500

- **Severity:** Medium
- **Spec:** request không hợp lệ → 400 (hoặc 415), server không được crash.
- **SUT:** gửi body dạng `application/x-www-form-urlencoded` → `TypeError: Cannot read properties of undefined` → 500.
- **Evidence:** M3-FR01-H02.
- **Issue:** (điền link)

BUG-M3-004 — FR-09: Công thức coupon percent sai hoàn toàn

- **Severity:** Critical (ảnh hưởng tiền)
- **Spec:** `discount = total_amount * discount_value / 100`.
- **SUT:** `discount = Math.floor(total_amount * (1 - coupon.discount_value))` — coi `discount_value` là hệ số nhân trực tiếp.
- **Evidence thật (probe live):** POST `/api/apply-coupon` body `{"code": "SAVE10", "total_amount": 299999}` với SAVE10 percent 10 trả về:

```
{"success": true, "coupon_id": 11, "discount_amount": -2699991, "final_amount": 2999990, "message": "Áp dụng thành công! Giảm 10%"}
```

Discount âm -2,699,991 — khách được "giảm" thành tăng giá, hoặc nếu `discount_value` lớn thì final âm. Theo spec discount phải là 29,999 (làm tròn) và final 269,999.
- **Evidence Newman:** các case percent trong `02_Bug_Discovery_Suite/FR-09` fail vì `discount_amount` lệch hàng chục lần.
- **Issue:** (điền link)

BUG-M3-005 — FR-09: Điều kiện C3 dùng > thay vì >=

- **Severity:** High
- **Spec:** C3 — `total_amount` lớn hơn hoặc bằng `min_order_amount`.
- **SUT:** `if (total_amount > coupon.min_order_amount)` — đơn hàng đúng bằng ngưỡng bị từ chối.
- **Evidence:** M3-FR09-014 (SAVE10, total = 300000 = min) kỳ vọng 200, SUT trả 400 "Đơn hàng chưa đủ giá trị tối thiểu 300,000 đ...".
- **Issue:** (điền link)

BUG-M3-006 — FR-09: Không cần đăng nhập vẫn áp được coupon (bypass C4)

- **Severity:** Critical (SEC-02)
- **Spec:** C4 yêu cầu xác thực JWT; thiếu token → 401.
- **SUT:** POST /api/apply-coupon không gắn middleware auth — gọi không token vẫn 200.
- **Evidence:** M3-FR09-H01 (apply BIGBUY không Authorization header → 200, kỳ vọng 401).
- **Issue:** (điền link)

BUG-M3-007 — FR-09: Bypass giới hạn số lần dùng (C5) bằng cách bỏ user_id

- **Severity:** Critical
- **Spec:** C5 — số lần dùng còn lại của user; hết lượt → 400.
- **SUT:** block kiểm tra uses chỉ chạy if (user_id). Omit user_id → không bao giờ bị chặn, dùng VIP100 (max 2) vô hạn.
- **Evidence:** M3-FR09-H05 — omit user_id, kỳ vọng 400, SUT trả 200.
- **Issue:** (điền link)

BUG-M3-008 — FR-09: IDOR — user_id do client tự khai, không đối chiếu token

- **Severity:** High (SEC-05)
- **Spec:** quota coupon gắn với user đăng nhập.
- **SUT:** body nhận user_id bất kỳ; user A khai user_id của user B → quota tính cho B, A dùng hết lượt của B (và ngược lại có thể đốt quota người khác).
- **Evidence:** M3-FR09-H02.
- **Issue:** (điền link)

BUG-M3-009 — FR-09: Sai thứ tự kiểm tra điều kiện (min-order trước expiry)

- **Severity:** Low/Medium (contract)
- **Spec:** thứ tự C1 → C5; coupon hết hạn phải báo hết hạn.
- **SUT:** kiểm tra total_amount > min_order_amount trước khi kiểm tra

expired_at; coupon EXPIRED với total nhỏ trả lỗi "chưa đủ giá trị tối thiểu" thay vì "đã hết hạn".

- **Evidence:** case expiry-order trong 02_Bug_Discovery_Suite/FR-09.
- **Issue:** (điền link)

BUG-M3-010 — FR-09: final_amount âm, không clamp về 0

- **Severity:** High
- **Spec:** final_amount = total - discount, hợp lý phải ≥ 0 .
- **SUT:** với coupon percent giá trị lớn (tạo được nhờ BUG-M3-014, ví dụ percent 1000) → discount > total → final_amount âm.
- **Evidence:** case percent-overflow trong Discovery; kết hợp BUG-M3-004/014.
- **Issue:** (điền link)

BUG-M3-011 — FR-17: SEC-03 — mọi endpoint coupon admin nhận token của user thường

- **Severity:** Critical
- **Spec:** GET /api/coupons, POST /api/admin/coupons, DELETE /api/admin/coupons/:id chỉ dành cho admin; user thường → 403.
- **SUT:** authenticateToken (server.js ~dòng 100–110) chỉ verify chữ ký JWT, không kiểm tra role. User thường:
 - GET /api/coupons → 200 (leak toàn bộ coupon) — M3-FR17-006
 - POST /api/admin/coupons → 200 (tạo coupon giả) — M3-FR17-007, M3-FR17-H02
 - DELETE /api/admin/coupons/1 → 200 (xóa thật SAVE10 của hệ thống) — M3-FR17-008
- **Impact:** phá dữ liệu + gian lận khuyến mãi. Đây là bug nghiêm trọng nhất được tìm thấy.
- **Issue:** (điền link)

BUG-M3-012 — FR-17: DELETE luôn trả 200, kể cả id không tồn tại / không phải số

- **Severity:** Medium
- **Spec:** id không tồn tại → 404.
- **SUT:** DELETE /api/admin/coupons/99999 → 200; DELETE

`/api/admin/coupons/abc` → 200. Không kiểm tra affected rows.

- **Evidence:** M3-FR17-009, M3-FR17-028, M3-FR17-H04.
- **Issue:** (điền link)

BUG-M3-013 — FR-17: Trùng mã coupon → 500 (SQLITE_CONSTRAINT) thay vì 409

- **Severity:** Medium
- **Spec:** mã trùng → 409 Conflict với JSON lỗi rõ ràng.
- **SUT:** POST `/api/admin/coupons` với code đã tồn tại → 500 kèm lỗi SQLite thô (khi constraint còn hiệu lực).
- **Evidence:** M3-FR17-H05 (SAVE10 còn tồn tại → 500).
- **Issue:** (điền link)

BUG-M3-014 — FR-17: Tạo coupon không validate gì (14 case invalid đều 200)

- **Severity:** High
- **Spec:** validate code khác rỗng, $type \in \{\text{percent}, \text{fixed}\}$, $discount_value > 0$ (percent ≤ 100), $min_order_amount \geq 0$, $max_uses_per_user \geq 1$, `expired_at` hợp lệ và trong tương lai; sai → 400.
- **SUT:** tất cả đều 200 và ghi vào DB: | Case | Body sai | SUT | | --- | --- | --- | | M3-FR17-011 | body rỗng {} | 200 | | M3-FR17-012 | discount_value âm | 200 | | M3-FR17-013 | min_order_amount âm | 200 | | M3-FR17-014 | max_uses_per_user = 0 | 200 | | M3-FR17-015 | type = "bogus" | 200 | | M3-FR17-017 / M3-FR17-H03 | percent = 1000 | 200 | | M3-FR17-018 | thiếu code | 200 | | M3-FR17-019 | thiếu expired_at | 200 | | M3-FR17-029 | discount_value là string | 200 | | M3-FR17-030 | expired_at sai format | 200 | | M3-FR17-033 | code rỗng | 200 | | M3-FR17-034 | percent = 0 | 200 |
- **Impact:** kết hợp BUG-M3-004 tạo coupon percent 1000 → discount âm / final âm ở FR-09.
- **Issue:** (điền link)

BUG-M3-015 — FR-17: Lệnh path — spec GET `/api/admin/coupons`, SUT chỉ có GET `/api/coupons`

- **Severity:** Medium (contract)
- **Spec:** endpoint liệt kê coupon của admin là GET `/api/admin/coupons`.

- **SUT:** GET /api/admin/coupons → 404; chỉ có GET /api/coupons.
- **Evidence:** M3-FR17-H01.
- **Issue:** (điền link)

BUG-M3-016 — FR-09: user_id dạng string bị từ chối 400 thiếu nhất quán

- **Severity:** Low
- **Spec:** body schema không nói rõ phải reject user_id string; nhưng SUT reject string trong khi lại cho phép omit hẳn (BUG-M3-007) — hành vi không nhất quán.
- **Evidence:** case user_id: "6" trong Discovery FR-09.
- **Issue:** (điền link)

BUG-M3-017 — FR-17: Tạo lại mã vừa xóa thành công mà không có dấu vết audit / ràng buộc

- **Severity:** Low (hardening)
- **Spec:** quản lý coupon cần nhất quán; mã đã xóa có thể được tạo lại với tham số khác (ví dụ SAVE10 min 300000 → tạo lại min 1) và lập tức áp dụng được.
- **Evidence:** M3-FR17-008 (xóa SAVE10 bằng user token) + M3-FR17-010 (tạo lại SAVE10 min_order_amount = 1 → 200). Probe sau đó:
`{"code": "SAVE10", "total_amount": 299999}` → 200 dù spec yêu cầu 400 với min gốc.
- **Issue:** (điền link)

Tổng hợp

- **17 bug** được báo cáo (4 Critical, 5 High, 6 Medium, 2 Low).
- Bug AI-sinh case bắt được: BUG-M3-004/005/011/012/013/014/015 (qua Discovery Suite).
- Bug chỉ case human-added bắt được: BUG-M3-002 (case-insensitive), BUG-M3-003 (Content-Type), BUG-M3-006 (bỏ token), BUG-M3-007 (omit user_id), BUG-M3-008 (IDOR), BUG-M3-017 (delete → recreate chain) — đúng mục tiêu G9.3 của đề: phát hiện chỗ AI bỏ sót.
- Evidence thực thi: `newman/member-3/bug-discovery-report.html` (chạy thật trên `http://localhost:3000`, reseed trước khi chạy).